

JFN — DOCUMENTO ADICIONAL: Due Diligence & OSINT (porquê, como e ferramentas gratuitas)

Companheiro do `JFN-DOCUMENTO-MESTRE-CONSOLIDADO.md` (já enviado). Aqui está a **fundamentação metodológica** — por que e como fazer due diligence e OSINT de forma profissional e defensável — e um **catálogo de ferramentas 100% gratuitas**, marcando o que já existe no JFN e o que vale integrar. Contexto: deputado estadual do RJ, fiscalização de recursos públicos. Tudo orientado a produzir **achados auditáveis** que sustentem requerimento/representação ao controle externo. Data: 2026-06-08.

PARTE A — DUE DILIGENCE

A.1. O que é e por que fazer

Due diligence é a **investigação independente e proporcional ao risco** de uma contraparte (aqui: fornecedor do Estado, órgão, pessoa) para formar um “retrato completo e honesto” da sua idoneidade, estrutura, histórico e red flags **antes** de uma decisão — e para deixar um **registro defensável**.

Por que importa no seu mandato (não é burocracia):

- **Prevenção, não autópsia.** A boa due diligence pega o risco antes do dano (edital direcionado, fornecedor laranja, sobrepreço) — e é o que diferencia fiscalização de denúncia tardia.
- **Registro defensável.** O propósito declarado da DD é criar um trilho documental que se sustenta perante o controle externo: cada conclusão amarrada a fonte, data e fundamento. É o que transforma um “achei estranho” numa representação ao TCE-RJ que se sustenta.
- **Beneficiário final.** O coração da DD é furar a casca da PJ até a **pessoa natural** por trás (sócios, laranjas, parentesco, vínculo político) — exatamente o que pega desvio.
- **Foco proporcional ao risco.** Não se investiga tudo igual: concentra-se onde o risco é maior (alto valor, dispensa, concentração, vínculo).

A.2. Os três níveis (calibre pelo risco)

1. **Nível I — Desktop básico:** cadastro, situação, sócios, sanções, mídia. Fontes abertas. Triagem rápida.

2. **Nível II — Conduzido por analista:** pesquisa independente ampla e profunda em bases abertas e especializadas, cruzamentos, rede societária, mídia adversa; **relatório formal** com red flags. É o nível-padrão para um fornecedor relevante.
3. **Nível III — Reforçada (enhanced):** validações de campo, entrevistas, verificação on-site, confirmação de existência real (endereço, capacidade operacional) — para os casos de alto risco/alto valor.

A.3. Como fazer — estrutura do relatório de DD

Estrutura consagrada (WEF/PACI + Transparency International), que **já está alinhada ao padrão do JFN**:

1. **Identificação** — alvo, CNPJ/CPF, objeto, período, analista, metodologia, fontes.
2. **Sumário executivo** — rating de risco visual, exposição, alertas prioritários.
3. **Perfil cadastral** — Receita/registro, situação, capital, porte, CNAE, data de abertura.
4. **Estrutura e beneficiários finais** — sócios (QSA), rede societária, co-endereço/contador, parentesco.
5. **Operações e capacidade** — a empresa tem estrutura real para o que entrega? (anti-fachada).
6. **Dados financeiros e contratos** — OBs (pagamento), contratos, concentração (HHI), aditivos.
7. **Verificação em listas restritivas** — CEIS/CNEP/CEPIM, sanções, inidoneidade TCE.
8. **Vínculos e conflito de interesse** — doações eleitorais x contratos; vínculo com agentes públicos.
9. **Mídia adversa** — notícias, processos, reputação.
10. **Red flags** — cada um com fundamento legal (artigo + acórdão).
11. **Matriz de risco P×I + conclusão (grau de atenção) + recomendações de encaminhamento.**
12. **Ressalvas** — indícios, presunção de legitimidade, nunca afirma crime.

Liga ao JFN: isto é exatamente o relatório de inteligência de fornecedor + parecer Lex. As lacunas que as Ondas 2–7 do documento mestre fecham (conflito doador↔contrato, sobrepreço com referência, grafo societário, dossiê 360, estética HTML→PDF) elevam a DD do JFN ao **Nível II profissional**.

A.4. Red flags clássicos de integridade (resumo)

Empresa recém-aberta que já ganha grande contrato · sócio/contador/endereço comum entre "concorrentes" · concentração >60% num único órgão · série de dispensas logo abaixo do teto · aditivos somando >25% · preço fora da referência de mercado · doador de campanha que vira fornecedor acima da mediana · ausência de publicação no PNCP · pagamento sem atesto/medição. (Detalhe e fundamento: docs/LEX-BASE-JURIDICA.md .)

PARTE B — OSINT (Open-Source Intelligence)

B.1. O que é e por que

OSINT é a coleta e análise **lícita e passiva** de informação **publicamente acessível** (sites, registros públicos, redes, arquivos, imagens) transformada em **inteligência acionável**. Não inclui invasão, credential stuffing nem acesso não autorizado — isso a descaracteriza e a torna inútil juridicamente.

Por que serve à fiscalização: a maior parte do que prova desvio **já é pública** (contratos, sócios, doações, nomeações, imóveis, notícias) — só está dispersa. OSINT é a disciplina de **conectar os pontos dispersos** num quadro coerente e defensável. É o motor por trás das suas investigações de rede (Amorim, Cozzolino) — formalizá-la torna o processo repetível.

B.2. O ciclo de inteligência (a metodologia profissional)

OSINT sério segue um ciclo, não "sair googlando":

1. **Planejamento e direção** — definir a pergunta exata (não "investigar fulano", mas "identificar se a empresa X tem sócio vinculado ao gabinete Y e contrato com a UG Z"). Aqui já se define **OPSEC** e a **legalidade/ética**.
2. **Coleta** — reunir dados das fontes abertas certas, com captura disciplinada (timestamp + URL).
3. **Processamento** — estruturar, traduzir, normalizar (CNPJ, nomes, datas).
4. **Análise** — correlacionar, **triangular** (≥ 2 fontes independentes por afirmação), achar padrões, **pivotar** (de um dado para o próximo: e-mail → domínio → empresa → sócio).
5. **Disseminação** — relatório defensável.

B.3. Princípios inegociáveis (o que separa profissional de amador)

- **Verificação/triangulação**: uma afirmação só "existe" se confirmada por fonte independente. Nada de print solto.
- **Documentação defensável**: capturar **timestamp + URL + cópia/arquivo**, e idealmente **hash** do artefato (prova de não-adulteração). Guardar em base segura. Documentar

inclusive os **negativos** ("não encontrado em X").

- **OPSEC:** não vazar a própria investigação (consultas logadas, fingerprint do navegador). Para um agente público investigando, vale separar identidade de pesquisa do perfil pessoal.
- **Legalidade e ética (LGPD):** só fonte pública e lícita; finalidade legítima de controle público; foco em **recursos públicos e agentes públicos**, não em devassa de cidadão privado; sem assédio. Ferramentas de reconhecimento facial / sock puppets existem, mas levantam sério risco ético-legal para quem ocupa cargo — use com extrema parcimônia e propósito estritamente fiscalizatório, ou evite.

B.4. OSINT alimenta a Due Diligence

Na prática são a mesma coisa em camadas: o OSINT é o **método de coleta/verificação**; a DD é o **produto estruturado**. O ciclo de inteligência (B.2) preenche os blocos do relatório de DD (A.3), e os princípios (B.3) garantem que o relatório se sustente no TCE-RJ/MP-RJ.

PARTE C — FERRAMENTAS GRATUITAS (catálogo curado)

Legenda: **[JFN]** = já existe/integrado no ecossistema · **[INTEGRAR]** = vale plugar no JFN · **[MANUAL]** = uso interativo (você/equipe), difícil/desnecessário automatizar.

C.1. Empresas e beneficiários finais

Ferramenta	O que dá	Acesso	Status
OCCRP Aleph	1B+ registros: registros empresariais, sanções, vazamentos, registros judiciais de 180+ países; cruza seus próprios dados (modelo FollowTheMoney)	grátis, hospedado (público + acesso ampliado p/ pesquisadores/sociedade civil)	[MANUAL] ★
OpenCorporates	Registros de empresas de 170+ jurisdições, unificado	grátis (conta "Permitted User" p/ jornalistas/ONG/acadêmicos); tem API	[INTEGRAR]
Open Ownership Register	Beneficiários finais (países selecionados)	grátis	[MANUAL]

Receita/CNPJ via BrasilAPI	Cadastro + QSA (sócios)	grátis, sem chave	[JFN]
Brasil.io	Datasets abertos (CNPJ completo, gastos, sócios)	grátis	[INTEGRAR]
Casa dos Dados / Consulta Sócios	Busca reversa de sócios, CNPJs por sócio	freemium	[MANUAL]

C.2. Sanções, PEP e idoneidade

Ferramenta	O que dá	Acesso	Status
OpenSanctions	Sanções globais + PEPs (pessoas politicamente expostas); modelo FtM; API	grátis p/ uso não comercial	[INTEGRAR]
CEIS/CNEP/CEPIM (Portal da Transparência)	Empresas sancionadas/inidôneas no Brasil	grátis (API c/ chave grátis)	[JFN]
SanctionsExplorer / OFAC / UE Sanctions Map	Sanções internacionais	grátis	[MANUAL]

C.3. Análise de rede / link analysis

Ferramenta	O que dá	Acesso	Status
FollowTheMoney (FtM)	Modelo de dados padrão de investigação financeira (pessoas, empresas, pagamentos) — para exportar/importar o grafo, não como plataforma a hospedar	open source (formato)	[INTEGRAR] ★
Maltego CE	Grafo de relações (pessoas, empresas, domínios) com "transforms"	grátis (limitado)	[MANUAL]
Gephi	Visualização/métricas de grafo (comunidades, centralidade)	open source	[INTEGRAR]
Grafo de Poder do JFN (Onda 4)	sócios+servidores+doações+contratos+nomeações	a construir	[JFN] ★

C.4. Pessoas, usernames, e-mail, redes

Ferramenta	O que dá	Acesso	Status
Sherlock / Maigret / Blackbird	Procura um username em centenas de plataformas	open source	[MANUAL]
Holehe	Em quais sites um e-mail está cadastrado	open source	[MANUAL]
theHarvester / Recon-ng	E-mails, subdomínios, nomes a partir de um domínio	open source	[MANUAL]
SpiderFoot	Automação OSINT sobre 100+ fontes (domínio/e-mail/IP)	open source	[MANUAL]

C.5. Documentos e vazamentos

Ferramenta	O que dá	Acesso	Status
OCCRP Aleph	Busca em vazamentos + cruzamento com seus docs	grátis, hospedado	[MANUAL]
ICIJ Datashare	Análise/indexação de grandes lotes de documentos	open source (uso local sob demanda)	[MANUAL]
Google Pinpoint	OCR + busca + entidades em milhares de documentos	grátis (jornalistas/pesquisadores)	[MANUAL]

C.6. Imagem, vídeo e verificação

Ferramenta	O que dá	Acesso	Status
InVID-WeVerify	Verificação de vídeo/imagem (frames, reverse, metadados)	grátis	[MANUAL]
Reverse image (Google/Yandex/TinEye)	Origem/duplicatas de imagem	grátis	[MANUAL]
ExifTool	Metadados de arquivo (data, GPS, dispositivo)	open source	[INTEGRAR]
Forensically / FotoForensics	Forense de imagem (ELA, clonagem)	grátis	[MANUAL]

C.7. Geoespacial

Ferramenta	O que dá	Acesso	Status
QGIS	SIG completo (cruzar endereços, mapear)	open source	[INTEGRAR]
OpenStreetMap + Overpass Turbo	Consulta geográfica (o que existe num endereço)	grátis	[MANUAL]
Google Earth / Sentinel Hub	Imagem de satélite (verificar obra/imóvel)	grátis	[MANUAL]

C.8. Notícia e monitoramento

Ferramenta	O que dá	Acesso	Status
GDELT	Notícia global + tom + Global Knowledge Graph (pessoas/empresas)	grátis (DOC API + BigQuery)	[JFN/Onda 6,8] ★
Google News RSS	Manchetes por consulta	grátis	[JFN]

C.9. Diretórios e metaferramentas (ponto de partida)

Ferramenta	O que dá	Status
OSINT Framework	Diretório de centenas de ferramentas por categoria	[MANUAL]
Bellingcat Online Investigation Toolkit	Curadoria de ferramentas de investigação aberta	[MANUAL]
GIJN (Global Investigative Journalism Network)	Guias e tipsheets de método	[MANUAL]

C.10. Fontes públicas brasileiras (a base de tudo, já no radar do JFN)

Portal da Transparência (CEIS/CNEP/PEP/servidores, API) · **TSE Dados Abertos** (doações/candidatos/filiação) · **PNCP** (editais/contratos/atas/docs) · **Querido Diário** (diários oficiais municipais, Open Knowledge Brasil) · **DOERJ** · **SIAFE/TFE** · **Receita/CNPJ (BrasilAPI)** · **Brasil.io**. (Todas já mapeadas ou em uso no documento mestre.)

PARTE D — COMO ISSO POTENCIALIZA O JFN (recomendações — SEM auto-hospedar)

Decisão do Mestre Jorge: **não auto-hospedar nada**. Logo, tudo aqui usa serviços **hospedados/API gratuitos**. Estas recomendações são implementadas pela **Onda 12** do JFN-DOCUMENTO-MESTRE-CONSOLIDADO.md.

1. **OpenCorporates + OpenSanctions como enriquecedores de API no pipeline de DD** 🌟 — vínculos societários cross-jurisdição (OpenCorporates) e checagem de **sanções + PEP** (OpenSanctions, gratuito p/ uso não comercial) entram no perfil cadastral, na rede societária e no score de risco do fornecedor, ao lado de BrasilAPI e CEIS/CNEP. São chamadas de API — nada roda na sua infra.
2. **OCCRP Aleph hospedado como ferramenta [MANUAL]** — para “follow-the-money” e vazamentos quando um caso escala, use o Aleph hospedado **via navegador**, não integrado: as consultas são logadas pelo provedor, e para um agente público em investigação sensível isso é um motivo legítimo para **não automatizar**. O JFN só registra o link/achado no dossiê.
3. **Alinhar o “Grafo de Poder” (Onda 4) ao modelo FollowTheMoney (FtM)** — manter o grafo **nosso**, mas com export/import em FtM, para interoperar com Aleph/Gephi sob demanda **sem migrar de plataforma nem hospedar Aleph**.
4. **Adotar os padrões de documentação OSINT no relatório do JFN** (reforça Onda 7): cada número com **proveniência (fonte+data)**, **hash de integridade** e registro dos **negativos**. É o que faz o relatório se sustentar no TCE-RJ/MP-RJ.
5. **Datashare/Pinpoint como [MANUAL]** para lotes de documentos do SEI/PNCP quando a extração estruturada (Onda 5) não basta — uso interativo, não integração.
6. **Manter o restante [MANUAL] como caixa de ferramentas da equipe** (Sherlock, InVID, QGIS etc.): rendem mais usados sob demanda do que automatizados.

PARTE E — ÉTICA, LEGALIDADE E LIMITES (obrigatório para agente público)

- **Só fonte pública e lícita**; nunca invasão/engenharia social/acesso não autorizado.
- **Finalidade legítima de controle público (LGPD)**: o foco é **recurso público e agente público**. Dados pessoais de terceiros privados só quando estritamente necessários ao nexo de fiscalização.
- **Presunção de legitimidade**: o produto aponta **indícios e diligências**, nunca afirma

crime/improbidade (isso compete a TCE-RJ/MP-RJ/Judiciário após contraditório).

- **Reconhecimento facial / sock puppets / dados sensíveis:** alto risco ético-legal para quem ocupa cargo; evitar ou usar com parecer e parcimônia extremos.
 - **Trilha defensável:** preserve fonte, data, hash e cadeia — o valor do achado é proporcional à sua rastreabilidade.
-

FONTES (verificadas, jun/2026)

- Due diligence (níveis, propósito, red flags): GAN Integrity (Levels of Third-Party Due Diligence); Transparency International — *Anti-Bribery Guidance: Managing Third Parties*; WEF/PACI — *Good Practice Guidelines on Conducting Third-Party Due Diligence*; BDO — *FCPA Compliance Practical Guide*.
- OSINT (ciclo de inteligência, OPSEC, verificação, documentação): ShadowDragon — *What is OSINT (2026)*; Penlink — *Best Practices for Integrating OSINT*; OSINT Vault — *OSINT Handbook (2026)*; OSINT Bay — *Workflow & OPSEC Checklist*.
- Ferramentas: Bellingcat — *Online Investigation Toolkit* (OpenCorporates, OpenSanctions, Open Ownership, OCCRP Aleph, QGIS, InVID etc.); OCCRP — *Aleph / Aleph Pro* (acesso gratuito; OpenAleph open source); GIJN — *How to Get the Best from OCCRP's Aleph*; EBU — *Tracing beneficial ownership with OSINT*; listas "Best Free OSINT Tools 2026" (SpiderFoot, Maltego CE, Sherlock/Maigret, theHarvester).
- Brasil: Portal da Transparência (CEIS/CNEP), TSE Dados Abertos, PNCP, Querido Diário (Open Knowledge Brasil), Brasil.io, BrasilAPI — já referenciadas no documento mestre.